

C05- ASSESSMENT TOOL -3

NAME:S.Dhivyasri

REG NO.:192511246

COURSE :Cryptography and network security

COURSE CODE :CSA5113

1. Analyze the weaknesses of SSL and explain why TLS is considered more secure in modern web systems.

Answer:

SSL is an older security protocol and its early versions have several known vulnerabilities. SSL 2.0 and SSL 3.0 use outdated cryptographic mechanisms and are vulnerable to attacks such as downgrade attacks and POODLE. They also lack several improvements available in modern TLS. TLS is more secure because it provides stronger cryptographic algorithms, improved authentication, better integrity protection, and stronger key-exchange mechanisms. TLS 1.3 also removes many obsolete algorithms and simplifies the handshake process. Therefore, modern web systems use TLS instead of SSL.

2. Apply the TLS handshake process to explain how secure session keys are established between a client and server.

Answer:

The TLS handshake establishes the security parameters before data transmission.

1. The client sends a ClientHello containing supported TLS versions and cipher suites.
2. The server responds with ServerHello and selects the cryptographic parameters.
3. The server sends its digital certificate.
4. The client validates the certificate and authenticates the server.
5. The client and server perform a secure key-exchange process.
6. Both independently derive the same symmetric session keys.
7. The handshake is verified.

8. The session keys are then used to encrypt and authenticate application data.

The important point is that public-key cryptography helps establish the shared secret, while

efficient symmetric cryptography protects the actual session.

3. Compare SSL and TLS in terms of encryption mechanisms and identify key improvements in TLS.

Answer:

SSL is an older protocol with obsolete cryptographic algorithms and weaker security

mechanisms. TLS is its successor and provides stronger cryptographic protection.

The major improvements in TLS include stronger cipher suites, improved key exchange,

better integrity protection, improved authentication, and protection against several protocol-level attacks. TLS 1.3 further removes outdated algorithms and reduces handshake

complexity.

Therefore, TLS is significantly safer and more suitable for modern communication than SSL

4. Evaluate a scenario where improper certificate validation in TLS leads to a security breach. What could go wrong?

Answer:

Suppose a banking application accepts a server certificate without properly checking the

certificate's hostname or trust chain. An attacker could present a fraudulent certificate and

impersonate the legitimate server.

This could allow a man-in-the-middle attack. The attacker could potentially intercept or

modify sensitive communication, expose credentials or session information, and redirect

users to malicious services.

Proper TLS certificate validation should verify the certificate chain, hostname, validity

period, and trusted Certificate Authority.

5. Analyze the role of digital certificates in SSL/TLS and explain how they ensure authentication.

Answer:

A digital certificate associates a server's identity with its public key. It is normally issued and

digitally signed by a trusted Certificate Authority.

During a TLS connection, the client checks whether the certificate is trusted, valid, and

appropriate for the requested hostname. The server also proves possession of the

corresponding private key.

Therefore, digital certificates allow the client to verify the identity of the server and reduce

the risk of server impersonation.

6. Apply your understanding of SET protocol to explain how it protects credit card transactions in e-commerce.

Answer:

SET stands for Secure Electronic Transaction. It was designed specifically to protect

credit-card transactions over the Internet.

SET uses encryption, digital certificates, and digital signatures to provide confidentiality,

authentication, and integrity. It separates order information from sensitive payment

information so that the merchant does not directly receive all the customer's card details.

The payment gateway communicates with the financial institution to authorize the

transaction.

7. Evaluate the limitations of the SET protocol in current online payment systems.

Answer:

The major limitation of SET is its complexity. It requires extensive certificate management

and participation from customers, merchants, payment gateways, and financial institutions.

It also increases implementation and operational costs and provides a more complicated user

experience. Modern payment systems have adopted simpler approaches based on TLS,

tokenization, strong authentication, and payment-provider security mechanisms.

Therefore, SET is historically important but is not widely used as the primary payment security protocol today.

8. Compare SET protocol with TLS-based payment security and justify which is more practical today.

Answer:

SET was specifically designed for secure electronic payment transactions and uses extensive

certificate-based authentication. However, it is complex to deploy.

TLS provides secure communication between a client and server and is already supported by

browsers, mobile applications, APIs, and payment systems.

Therefore, TLS-based security is more practical today because it is widely supported,

easier to deploy, and can be combined with tokenization, authentication, and other payment security mechanisms.

9. Analyze a malware attack scenario and differentiate whether it is caused by a virus, worm, or Trojan.

Answer:

Suppose an employee downloads a program that appears to be legitimate software. After

installation, the program performs unauthorized activities.

This is most likely a Trojan, because it disguises itself as legitimate software and relies on

the user installing or executing it.

A virus attaches itself to files or programs and spreads when they are executed. A worm

automatically replicates and spreads through networks. A Trojan mainly depends on

deception and user execution

10. Apply appropriate mitigation techniques for a worm attack spreading across a corporate network.

Answer:

First, infected systems should be isolated to prevent further propagation. Network

segmentation and firewall controls should then be used to restrict unnecessary

communication.

The organization should:

- Patch vulnerable systems.
- Disable unnecessary services.
- Update endpoint protection.
- Monitor network traffic using IDS/IPS.
- Block suspicious network activity.
- Reset compromised credentials when necessary.
- Restore affected systems from trusted backups.

The main objective is to contain, remove, patch, and recover.

11. Evaluate the impact of Trojan attacks on system confidentiality and integrity with an example scenario.

Answer:

A Trojan can compromise confidentiality by providing unauthorized access to sensitive

information. It can also affect integrity by modifying files or system settings.

For example, an employee installs a fake document application. The program appears

legitimate but secretly accesses organizational documents and modifies files.

This can result in data exposure, unauthorized modification, credential compromise, and loss

of trust in the affected system.

12. Compare viruses, worms, and Trojans based on propagation method and system impact.

Answer:

Feature	Virus	Worm	Trojan
Propagation	Through infected files/programs	Automatically through networks	Usually through user installation
User involvement	Often required	Usually not required	After initial infection

Usually required

Main

characteristic

File infection Self-propagation Disguised malicious software

Impact File/program damage Network disruption Unauthorized access/data theft

In simple terms: Virus = infects files, Worm = spreads automatically, Trojan = disguises itself.

13. Analyze the working of a packet-filtering firewall and identify its limitations in modern networks.

Answer:

A packet-filtering firewall examines packet information such as source IP, destination IP, port numbers, and protocol. It compares these values with predefined rules and either allows or blocks the packet.

Its limitations include:

- It has limited understanding of application content.
- It may not understand connection context.
- It cannot effectively detect sophisticated application attacks.
- Encrypted traffic can hide malicious content.
- Large rule sets can become difficult to manage.

Therefore, modern networks usually combine packet filtering with stateful firewalls, application controls, IDS/IPS, and endpoint security.

14. Apply firewall rules to block unauthorized access while allowing legitimate traffic in a given scenario.

Answer:

Consider a company web server that should accept HTTPS traffic but should not allow public

access to its administrative services.

Example rules:

- Allow TCP port 443 for HTTPS.
- Allow port 80 only if HTTP is required.
- Block external access to administrative ports such as SSH.
- Block external access to database ports.
- Block known malicious source addresses.
- Block all other unsolicited inbound traffic.

This follows a default-deny principle while allowing only required services.

15. Evaluate the effectiveness of stateful inspection firewalls over stateless firewalls.

Answer:

A stateless firewall examines each packet independently. A stateful firewall maintains

information about active connections.

Stateful inspection is generally more effective because it understands whether a packet

belongs to an established connection. It can therefore distinguish legitimate response traffic

from unsolicited traffic.

For example, when an internal user starts a secure web connection, the stateful firewall can

recognize the returning packets as part of that legitimate session.

Therefore, stateful firewalls provide better context and security than basic stateless packet

filtering.

16. Compare different types of firewalls and recommend the most suitable one for an enterprise network.

Answer:

The major types include:

1. Packet-filtering firewall – Filters packets based on IP addresses, ports, and

protocols.

2. Stateful firewall – Tracks active connections.

3. Proxy/application firewall – Examines application-level communication.

4. Next-Generation Firewall (NGFW) – Combines traditional firewall functions with

advanced inspection and security features.

For a modern enterprise, an NGFW is generally the most suitable because it can provide

application-aware filtering, intrusion prevention, user-based controls, and advanced traffic

inspection.

18. Apply IDS/IPS mechanisms to prevent a distributed denial-of-service (DDoS) attack.

Answer:

The IDS monitors traffic patterns and identifies unusual increases in connection requests,

traffic volume, or protocol activity.

When suspicious behavior is detected, the IPS can automatically apply appropriate controls

such as blocking clearly malicious traffic or rate-limiting suspicious requests.

For large-scale DDoS attacks, organizations should also use upstream DDoS protection

because an internal IPS alone may not be able to handle extremely high traffic volumes.

Thus, IDS provides detection and visibility, while IPS provides automated prevention

20. Propose improvements to reduce false positives in an IDS while maintaining high detection accuracy.

Answer:

False positives can be reduced by improving the quality and context of detection.

Important techniques include:

- Regularly tune IDS rules.
- Establish accurate normal-traffic baselines.
- Use both signature and anomaly detection.
- Consider user, device, application, and network context.
- Assign severity levels to alerts.
- Carefully whitelist verified legitimate activity.
- Keep attack signatures updated.
- Correlate multiple related events.
- Continuously measure false-positive and false-negative rates.

The goal is to make the IDS generate fewer unnecessary alerts while keeping genuine

attacks highly visible.